

Security incident report

Section 1: Identify the network protocol involved in the incident

The protocols involved in this communication are the Domain Name System (DNS) and Hypertext Transfer protocol (HTTP).

While users made initial DNS requests to the intended web server, the users requests were redirected via a malicious download link initiated through a brute force that allowed the

Section 2: Document the incident

Incident Overview & Execution

The incident began when an attacker gained unauthorized access to the company website. by targeting the administrative portal. They bypassed security using a simple brute force attack. Because the admin account was still running on its default password and lacked any basic lockout controls, it was easy for them to guess the credentials. Once inside, the attacker modified the site's source code. They injected malicious JavaScript that forces visitors to download an executable file disguised as a mandatory browser update, and then changed the admin password to lock the legitimate owners out.

Impact & Detection

The impact became clear when customers started reaching out to the helpdesk. After downloading and running the prompted file, their browsers were silently redirected to a fake clone site that delivered malware. Users reported unexpected download prompts, sudden URL changes, and their computers suddenly running very slowly. The issue was finally escalated when the website owner tried to log in, realized they were locked out, and contacted the hosting provider for emergency help.

Investigation & Root Cause Analysis

To figure out exactly what happened, I set up an isolated sandbox to safely test the site while running tcpdump to capture the network traffic. When I visited

the official website, the site immediately prompted me to download the executable. I let it run in the sandbox and tracked the packet logs. The traffic clearly showed the browser making initial DNS and HTTP requests to the legitimate site, downloading the malware, and then immediately making new DNS and HTTP requests to the attacker's domain.

A senior analyst confirmed the injected JavaScript in the source code and found the redirect script inside the downloaded file. Ultimately, the root cause was a straightforward brute force attack, made possible only because the admin account was on default password.

Section 3: Recommend one remediation for brute force attacks

Implement Account Lockout Policies and Rate Limiting: To directly neutralize brute force attacks, the Operating System and web application must be configured to automatically lock user accounts after a maximum of 3 to 5 consecutive failed login attempts. Because brute force attacks rely on making thousands of rapid password guesses, an account lockout instantly halts the attack by cutting off access at the source. This should be paired with a mandatory cooldown period or requiring administrator intervention to unlock the account, ensuring the attacker cannot simply resume guessing.